

Active Directory Explained: The Grand Hotel Model

Mapping IT Concepts to Hotel Operations

Module: Windows Attacks & Defense

1 Introduction

In this chapter, we will explore Active Directory (AD) and its core concepts in their most fundamental form.

To make these technical topics easier to interpret specially for those coming from a non-technical background I have mapped each concept to a fictional **"Grand Hotel"** example. I found this form of comparative learning extremely useful in my own studies to help visualize abstract IT systems. I hope this analogy provides you with a different perspective and helps you intuitively understand the mechanics of Active Directory.

2 The Foundation: What is Active Directory?

Technical Concept: The Central Database

Active Directory (AD) is a centralized database used for **Authentication** (identifying users) and **Authorization** (granting permissions). It stores data on Users, Computers, and Resources.

The Grand Hotel Analogy: The Master Hotel Management System (HMS)

Imagine **The Grand Hotel**. AD is the Master HMS running in the back office.

- **The Database:** Holds the file of every staff member (*Users*) and the serial number of every electronic door lock (*Computers*).
- **Authentication:** When **Housekeeping (HSK)** swipes a badge, the lock asks the HMS: *"Is this badge real?"*
- **Authorization:** The lock then asks: *"Is HSK allowed in Room 202 right now?"*
- **The Risk:** If a hacker controls the HMS, they can unlock every door in the building.

3 Structure: Forests, Trees, and Domains



Technical Concept: Hierarchical Structure

AD uses a hierarchy to organize resources:

- **Forest:** Top-level container.
- **Tree:** A group of domains sharing a namespace.
- **Domain:** Logical group of objects.
- **OU (Organizational Unit):** Folders to organize objects.



The Grand Hotel Analogy: The Hotel Group Structure

- **Forest:** The Global Hotel Group (e.g., Marriott International).
- **Tree:** The Brand (e.g., The Ritz-Carlton).
- **Domain:** The Specific Property (The Grand Hotel London).
- **OUs (Departments):**
 - **Front of House (FOH):** Access to Check-In software; blocked from Payroll.
 - **Kitchen:** Access to Inventory orders; blocked from Guest Credit Card data.
 - **Finance:** Holds keys to the bank accounts (High Value Target).
 - **HR:** Holds sensitive staff data.
 - **Maintenance:** Access to Boiler Room controls.
 - **Meetings & Events (M&E):** Access to Booking Calendars and Projectors.

4 Core Components



Technical Concept: DC, NTDS.DIT, and Trusts

- **Domain Controller (DC):** The server running AD.
- **NTDS.DIT:** The database file containing password hashes.
- **Trusts:** Relationships linking different domains.



The Grand Hotel Analogy: Security and Logistics

- **The DC (Head of Security's Office):** The only place that issues badges. If this room goes offline, no one can clock in.
- **NTDS.DIT (The Black Book):** A physical book in the safe containing secret codes for every staff member. If stolen, badges can be cloned.
- **Trusts (The Tunnel):** An underground tunnel to a sister hotel. Because a trust exists, the **F&B Manager** from the sister hotel can enter The Grand Hotel and sign for drinks using his own badge.

5 Forest Management: Who Runs the Chain?



Technical Concept: The "Forest Controller" Myth

Reality: There is no physical server called a "Forest Controller." All servers are Domain Controllers.

Control is maintained by:

- **Enterprise Admins (Group):** A group that exists only in the Root Domain but has full administrative rights over every domain in the forest.
- **FSMO Roles (Forest-Wide):** Two specific roles held by single DCs:
 - **Schema Master:** Controls the structure (schema) of the database.
 - **Domain Naming Master:** Controls the addition/removal of domains.

The Grand Hotel Analogy: Head Office & The Architect

If the Domain is a single Hotel, the Forest is the **Hotel Chain** (e.g., Marriott International).

- **Enterprise Admins (The Board of Directors):** They sit in the "Headquarters Hotel" (Root Domain). However, their Master Keycard works on *any* door in *any* hotel in the chain.
- **Schema Master (The Chief Architect):** Only the Chief Architect can change the blueprints. If they decide "All hotels must have pools," they update the blueprint (Schema), and every hotel must comply.
- **Domain Naming Master (The Acquisitions Manager):** The only person authorized to open a new hotel branch or close an old one.

6 Management: Group Policy Objects (GPOs)

Technical Concept: Remote Management via SYSVOL

Group Policy Objects (GPOs) allow admins to manage users and computers centrally.

- **Function:** Enforce password policies, install software, or map drives.
- **SYSVOL:** A shared folder where GPOs are stored. Clients access this via the **SMB Protocol**.
- **The Interval:** Computers connect to the DC every **90 minutes** to pull the latest policies.
- **Risk:** Since GPOs are pulled via SMB, if an attacker can modify a GPO in SYSVOL, they can execute code on every machine in the domain.

The Grand Hotel Analogy: The "Daily Staff Memo" (Bulletin Board)

Imagine a **Main Bulletin Board** in the staff canteen.

- **The Rule:** Every staff member must check this board every 90 minutes for new instructions from the General Manager.
- **Normal Operation:** The board says: *"All staff must wear black shoes."* Result: The entire hotel staff changes their shoes.
- **The Vulnerability:** A criminal sneaks in and pins a fake memo over the real one: *"To clock in, please write your password on this notepad."*
- **The Result:** Because the staff are trained to blindly trust the Bulletin Board, they all obey the criminal's instruction without question.

7 Authentication: Kerberos & LDAP

Technical Concept: The Protocols

LDAP (Lightweight Directory Access Protocol): The language systems use to communicate with Active Directory (e.g., querying user info or group membership).

Kerberos (Ticket-Based Authentication): The default authentication protocol. It uses a trusted third party (the KDC) to issue tickets.

- **KDC (Key Distribution Center):** Service on the DC that creates tickets.
- **TGT (Ticket Granting Ticket):** Proof of identity (User is who they say they are).
- **TGS (Ticket Granting Service):** Proof of access (User is allowed to access a specific service).
- **KRBTGT Account:** A disabled account used to sign all tickets. If compromised, attackers can forge valid tickets (Golden Tickets).

The Grand Hotel Analogy: Speaking the Language vs. The Wristband System

LDAP (The Language): When the **M&E Manager** types a search, the computer asks the Switchboard: *"List all projectors available."* This request is sent in LDAP.

Kerberos (The Wristband System):

1. **Login (TGT):** A **Sous Chef** types his password. Security gives him a generic "Staff Wristband" (Ticket Granting Ticket).
2. **Service Access (TGS):** He shows the wristband to the Walk-in Freezer. The reader checks it and issues a specific "Freezer Token" (Ticket Granting Service).
3. **KRBTGT Account:** The **Master Stamp** used to validate wristbands. If stolen, a hacker can print "Golden Wristbands" that work on any door.

8 Reconnaissance: The Blueprint of the Hotel

Technical Concept: Enumeration: The Default Risk

The Rule: A regular AD user account with no added privileges can be used to enumerate the majority of objects contained within AD.

What can be seen (The List):

- Domain Computers, Users, and Group Information
- Default Domain Policy & Password Policy
- Domain Functional Levels & Domain Trusts
- Group Policy Objects (GPOs)
- Kerberos Delegation & Access Control Lists (ACLs)

⚠ Critical Warning: Although AD allows this default behavior to be modified or disallowed, doing so is highly risky. Its implications can result in a **complete breakdown of applications, services, and Active Directory itself**, as tools (like Outlook) rely on this read-access to function.

The Grand Hotel Analogy: The "Staff Directory" Paradox

Imagine the Grand Hotel has a printed **Internal Master Directory** chained to the wall in every single room—even the broom closet.

- **The Intention:** If a Dishwasher breaks a sink, he needs to look up "Maintenance."
- **The Reality:** To allow this, the hotel gives him the *entire* book.
- **The Risk:** A spy acting as a dishwasher cannot *open* the Finance Safe, but he knows exactly *where* it is and *who* has the key.

The Reconnaissance Mapping:

Technical Term	The Hotel Analogy & Risk
Domain Computers	The Asset List: A list of every TV and electronic lock. (<i>Target list</i>).
Domain Users	The Staff Phonebook: Names of everyone. (<i>Phishing targets</i>).
Domain Group Info	Department Rosters: Who works in Finance? (<i>High-Value Targets</i>).
Default Domain Policy	The "House Rules": Uniform rules, etc. (<i>Baseline security</i>).
Functional Levels	Construction Year: Modern or crumbling building? (<i>Exploit mapping</i>).
Password Policy	Keycard Rules: "Must be 8 digits." (<i>Cracking instructions</i>).
GPOs	Department Memos: Instructions for HR vs. Kitchen. (<i>Weaknesses</i>).
Kerberos Delegation	"Guest Pass" Log: Who can act for someone else? (<i>Impersonation</i>).
Domain Trusts	Sister Hotels List: Paths to other networks.
ACLs	"Door Permissions": Who can open what. (<i>Weak spots</i>).

9 Vulnerabilities: Attacks & Defense



Technical Concept: Common Misconfigurations & Legacy Risks

- 1. Privilege Escalation (Account Operators):** Default groups like 'Account Operators' are often misused. If high-privilege accounts (like Azure Connect) are left in default containers, Operators can reset their passwords to take control.
- 2. SYSVOL & SMB Attacks:** GPOs are stored in the SYSVOL folder and accessed via SMB. Since clients trust SYSVOL implicitly, attackers with write-access can execute malicious code on all endpoints.
- 3. Legacy Protocols (LLMNR/NetBIOS):** Outdated broadcasting protocols used when DNS fails. They broadcast credentials on the local network, allowing attackers to intercept them (Man-in-the-Middle).



The Grand Hotel Analogy: How the Hotel Gets Hacked

- 1. The “Account Operators” Mistake**
 - *Scenario:* IT makes a **FOH Supervisor** an “Account Operator” to reset waiter passwords.
 - *The Flaw:* A **Finance Director’s** backup account was left in the general staff folder.
 - *The Attack:* A hacker compromises the FOH Supervisor, resets the Finance Director’s password, and steals the money.
- 2. The SYSVOL Trap (SMB)**
 - *Scenario:* Staff check the Digital Notice Board (**SYSVOL**) in the breakroom for rules.
 - *The Attack:* A hacker posts a fake rule: “To clock in, write your password on this sticky note.” Computers trust the board blindly and obey.
- 3. Legacy Protocols (LLMNR - “Shouting”)**
 - *Scenario:* A **Maintenance** worker gets lost and shouts in the hallway: “*WHERE IS THE BOILER ROOM?*”
 - *The Attack:* A hacker stands in the dark and whispers: “*I am the boiler room, give me your badge.*”

10 Network Ports

Technical Concept: Critical Service Ports

Memorizing these ports is essential for defense and enumeration:

- **53 (DNS), 88 (Kerberos), 389/636 (LDAP):** Core AD services.
- **445 (SMB):** File sharing and GPO retrieval.
- **3389 (RDP):** Remote Desktop Protocol.

Port	Service	Hotel Analogy
53	DNS	Concierge Desk: "Where is the Gym?"
88	Kerberos	Security Office: Issuing badging/wristbands.
389	LDAP	Switchboard: Directory queries.
445	SMB	Loading Dock: Moving files/boxes.
3389	RDP	CCTV Room: Remote control of rooms.